

1. OVERVIEW

An overview of Requirement 5 (“Prevent Malware”), and its sub-requirements.



REQ. 5: PREVENT MALWARE

REQ. 5: PREVENT MALWARE **OVERVIEW**

Requirement 5 (Protect All Systems and Networks from Malicious Software) is all about keeping anti-virus and anti-malware solutions to prevent all types of viruses, worms, trojans, and others on machines that deal with CHD, eliminating vulnerabilities.

This requirement focuses mostly on:

- Addressing the various types of malware and having protection at the points they originate in (malicious websites, emails, links, etc);
- Ensuring that antivirus/antimalware software is not just installed, but running and updated;
- Actively protecting users from all types of malicious attacks;

REQ. 5: PREVENT MALWARE

OVERVIEW

The sub-requirements for this requirement include:

- 5.1 Processes and mechanisms for protecting all systems and networks from malicious software are defined and understood.
- 5.2 Malicious software (malware) is prevented, or detected and addressed.
- 5.3 Anti-malware mechanisms and processes are active, maintained, and monitored.
- 5.4 Anti-phishing mechanisms protect users against phishing attacks.





REQ. 5: PREVENT MALWARE

REQ. 5: PREVENT MALWARE **OVERVIEW**

5.1 Processes and mechanisms for protecting all systems and networks from malicious software are defined and understood

- Our usual sub-requirement. All processes and policies regarding anti-malware must be documented, updated, in use, and the same for documentation on associated roles and responsibilities;

This is usually tested through:

- Examining the documentation of these processes and policies, and interviewing personnel to ensure that everything is properly documented and corresponds to reality;

REQ. 5: PREVENT MALWARE **OVERVIEW**

5.2 Malicious software (malware) is prevented, or detected and addressed

- We must have an anti-malware solution that detects all malware types (and protects against them) on all systems and components. This is regardless of OS and machine;
- Exceptions can be made, but we must document and justify why these systems/components are not at risk;

This is usually tested through:

- Examining documentation and verifying systems and components to verify proper working of anti-malware;
- Examining processes to determine exceptions, verifying that periodic evaluations are performed + risks analyzed;





REQ. 5: PREVENT MALWARE

REQ. 5: PREVENT MALWARE **OVERVIEW**

5.3 Anti-malware mechanisms and processes are active, maintained, and monitored

- This sub-requirement is about the actual working of the anti-malware solution. It must be kept updated, it must perform periodic (or continuous) scans, it must scan removable media when inserted, and there must be logs;
- The solution must also not be removable by users;

This is usually tested through:

- Examining the anti-malware solution configurations;
- Examining system components and scan logs;
- Interviewing personnel and examining records to verify anti-malware cannot be disabled, and is running;

REQ. 5: PREVENT MALWARE

OVERVIEW

5.4 Anti-phishing mechanisms protect users against phishing attacks

- This is a small, but very specific sub-requirement. People who perform operations for PCI DSS compliance must be protected against phishing and social engineering;
- These protection mechanisms are not brought into PCI DSS compliance. Merely, the people who “do” PCI DSS must be protected. They are usually company-wide ones;

This is usually tested through:

- Observing implemented processes and mechanisms to verify that such controls exist, that they do work against phishing attacks, and that PCI DSS related personnel are protected;





REQ. 5: PREVENT MALWARE

REQ. 5: PREVENT MALWARE **OVERVIEW**

How can we summarize, then, this requirement?

- Basically, we need to have an anti-malware solution that protects against all sorts of attacks, on all systems and components in scope of the PCI DSS, always updated, always scanning, and that cannot be disabled;
- There may be exceptions (systems that don't need this protection), but they must be explicitly listed, inventoried, and analyzed;
- People who work in PCI DSS compliance must be protected by automated mechanisms that protect against phishing and social engineering (although these mechanisms are not considered to be in scope - merely "the people" are in scope);

REQ. 5: PREVENT MALWARE

OVERVIEW

EXAMPLES

/01 NO “COMMONLY AFFECTED”

In the PCI DSS v.3.2.1, only machines that could be “commonly affected” needed anti-malware. Now, all of them do, save for explicitly stated exceptions.

/02 STRONG REASONS

Individual users can request to turn off their AV temporarily, with a strong reason, via policies. For example, running a CPU-intensive operation isolated.

/03 “FREQUENT” IS KEY

Antivirus software must be frequently updated, frequently scan, and frequently log results. The frequency is not a specific one, but must make sense.

REQ. 5: PREVENT MALWARE

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization sets up a good anti-malware solution on all computers that receive payments through PoS systems, and only the admin can deactivate it;
- The organization educates staff on safe Internet practices, such as not download software, or clicking on suspicious links, against phishing;

E-COMMERCE STORE

- The organization installs anti-malware software on web servers, to monitor and block activities targeting the online store;
- The software runs malware scans on all systems, including website files and databases, to prevent any possible malicious code injections or file changes;

HOTEL CHAIN

- The organization implements enterprise-level anti-malware solutions across all locations, with centralized management for consistent policy enforcement;
- All systems are configured to automatically run scans and update the anti-malware solution, limiting non-admin access;

PAYMENT PROCESSOR

- The organization not only adopts an anti-malware solution, but also behavioral analysis and machine learning solutions to block advanced threats and zero-day exploits;
- The organization updates its IR plan to deal with malware accidents in particular, including containment, eradication and recovery;

REQ. 5: PREVENT MALWARE

OVERVIEW

KEY TAKEAWAYS

/01 PREVENT MALWARE

Requirement 5 is about constantly running AV software on all machines that is updated, regularly scans, logs results, and cannot be turned off.

/03 5.2 ANTI-MALWARE EXISTS

There must be an anti-malware solution that detects all types of malware, and that removes/blocks/contains all types.

/05 5.4 PHISHING IS PREVENTED

There must be mechanisms to protect PCI DSS-related people from phishing and social engineering.

/02 5.1 PROCESSES DEFINED

As usual, we must have documentation that is established, updated, and in use, as well as the definitions of roles and responsibilities here.

/04 5.3 ANTI-MALWARE WORKS

The solution must scan periodically/constantly, must be kept updated, must scan removable media on connection, must keep logs, and cannot be turned off.